

WEEKLY REPORT

Work done in last week (Attach supporting Documents):

1.

I have gone through the documents and have understood the objectives. I've also verified the tech stack and the security principles to keep in mind while developing the SproutSong portal. I would like to add another piece of information as we are using MongoDB. We have to make efforts to avoid attacks like noSQL Injection, Broken Access Control, avoid publicly exposed DB, credential stuffing attack, privilege escalation, data exfiltration, brute force, ransomware, insider threats, session hijacks or even JWT theft as mentioned in the document. We also need to prevent the upload of malicious files (usually have two extensions), injection using regex, DoS attacks, ensure encryption of data, have a backup, avoid misconfigured roles, do log sanitization and avoid cross tenant data leakage. Supply chain attack as well (already mentioned in document - npm auditing)

I opened the SproutSong website and familiarized myself with the portal.

Sprout mentors - it's for teachers / educators, I did the same for this web app.

2.

I received the GitHub credentials for my company account from the tech lead. I accessed the repo of SproutSong and cloned it.

I had to start with the Main Responsibilities section from the doc i.e. Part A: Data Mapping.

"<https://auth.sproutsong.com/request-demo>" is the URL for the "Request a Demo" form of the portal. I ran through the form and familiarized myself with it.

Then I accessed the repo via VS Code in order to inspect the codes and database schemas. I had to download node.js and other required dependencies and extensions.

Finally I was tasked with making an excel sheet which includes the schema of the form in a tabular form so as to generate a report for the security implementations for this particular form.

I then filled the actual form on the portal and received the logs generated from the owner and reviewed it to identify any vulnerabilities.

I realized that a few fields containing PII like phone number, name, address, etc. were stored as plaintext and were visible in the logs. These should be encrypted and be stored in unreadable format. Also the logs needed to be masked.

I found other relevant security implementations needed and generated a report for the same. The URL for the report:-

<https://claude.ai/share/b7737bd7-3d7d-4c58-928e-4c3267f7dcc0>

If I were to summarise the report from Claude, we basically need to:

- 1) Encrypt PII which is personally identifiable information like names, phone numbers, etc.
- 2) Validate the marked fields with proper format.
- 3) Mask the sensitive details in the logs generated, email, numbers, etc. should not be visible as PLAINTEXT in the logs that are generated.
- 4) Implement a mechanism to avoid cross site scripting.

Cross-Site Scripting (XSS) attacks are a type of injection, in which malicious scripts are injected into otherwise benign and trusted websites. XSS attacks occur when an attacker uses a web application to send malicious code, generally in the form of a browser side script, to a different end user. Flaws that allow these attacks to succeed are quite widespread and occur anywhere a web application uses input from a user within the output it generates without validating or encoding it. An attacker can use XSS to send a malicious script to an unsuspecting user. The end user's browser has no way to know that the script should not be trusted, and will execute the script. Because it thinks the script came from a trusted source, the malicious script can access any cookies, session tokens, or other sensitive information retained by the browser

and used with that site. These scripts can even rewrite the content of the HTML page. For more details on the different types of XSS flaws, https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

5) The user should also agree to the consent fields that we need to add. Also have to implement access control for fields that should only be accessed by the admin.

I think that adding consent fields, record of concept proof and backup of the proof as well as the data is most important for us as of now. Proof of consent should have a timestamp, IP and checkbox ticked by the user.

3.

Tasks for today:- (Make schema excel sheet and generate report as previously done for all forms)

SproutSong - forms:-

1. Request a demo - form (Done on 15th May)
2. Counselling form - Student counselling form - Review it and prepare the excel and include in report - URL:

<https://www.sproutsong.com/counselling/counselling-form>

3. Contact us form - SproutSong contact us form

4. AI workshop form - Schools to subscribe for AI workshop - URL:

<https://www.sproutsong.com/ai-workshop>

Answer questions like :-

1. What data do we collect?
 2. Why do we collect it?
 3. Where is it stored?
 4. Who can access it?
 5. How long do we keep it?
-

All 4 sheets are ready. Also I submitted the counselling, AI workshop and contact us forms on the website. Then I could see my input in db and logs. I reviewed that.

After that, I generated the reports for each using claude. The questions mentioned above and those in Part - B image were taken into consideration for the report.

Then I logged into the Sprout Mentors web app :
<https://app.sproutmentors.com/> with credentials provided to me and searched for other forms in it, which are similar and need similar security implementations under the DPDP Act.

Re-evaluated the logs for request a demo form after re-submitting the form, as some changes were made.

The PDF contains the detailed list of what security implementation needs to be done for each field and the HTML page is the report for all 4 forms based on the questions.

4.

Tasks :-

<https://app.sproutmentors.com/myclass/student/student-list>

Create a project in our Claude to use the existing schema and include in the report.
so schema like

Students

Classes

Assignments

Reports

Exams

Assessments

Activities

Home work

Attendance

Tasks (Project or any other activities)

Class Routine etc.

Search for other relevant modules and forms on Sprout Mentors that need security implementation according to the DPDP Act and generate a similar report. Same list of questions as Day - 3.

ChatGPT - DPDP Compliance Report :-

<https://chatgpt.com/share/6a0d6449-7834-83e8-84fc-09c2278044bf>

4th point of this specifies the Module-Wise DPDP Applicability. In point 7, you can see sample consent descriptions. And in point 8, you can see what security implementation is needed in each module.

This is more of a conceptual level so I added the schema and collection with GPT so I can have more in-depth analysis.

The schema collections:-

aitrainings

classes

contacts

educators

insights

mentors

seopages

Student_Task

students

students_attendances

substitutions

Syllabus_Progress

teacherprofiles

teachers

Requirements from GPT response:-

1. If any relevant fields are missing or not?
2. Check the types and suggest the changes considering security point of view
3. Does Captcha code provide the security from the front-end?
4. Can direct API calls from browser or terminal through curl call be prevented?
5. Any server side validation to prevent the attack ?
6. Middle ware implementation and security check - with node.js?
7. Mongodb - data protection

SUPPORTING DOCUMENTS HAVE BEEN ATTACHED IN DAILY REPORT GITHUB REPOSITORY.

Reason for incomplete work:

1. No Incomplete Work

Plans for next week:

1. Access Control, API Security, MongoDB Security as per part D and E of the Internship Guide Document.

References:

1. GitHub Repository (Check branch named Week-1) :-
<https://github.com/Rudra733/Internship-Daily-Reports/tree/Week-1>

Signature of External Guide

Signature of Internal Guide

Student Id : 24IT016
Student Name : Dodiya Rudra Ketansinh